

Cybersécurité

Sécurité des réseaux SEC/RES

Présentation et organisation du cours

Master 2, Sorbonne Université - Télécom Paris,

UE SEC/RES

Responsable : Prof. Rida Khatoun

rida.khatoun@telecom-paris.fr

- Présentation

- Responsable de l'UE :

- Rida Khatoun, Professeur, département INFRES
 - Bureau : 4C62 à Saclay !!
 - E-mail : rida.khatoun@telecom-paris.fr

- Responsable de TD/TP :

- Christophe Kiennert, Télécom Sud Paris
 - E-mail : christophe.kiennert@telecom-sudparis.eu

- Plan du cours

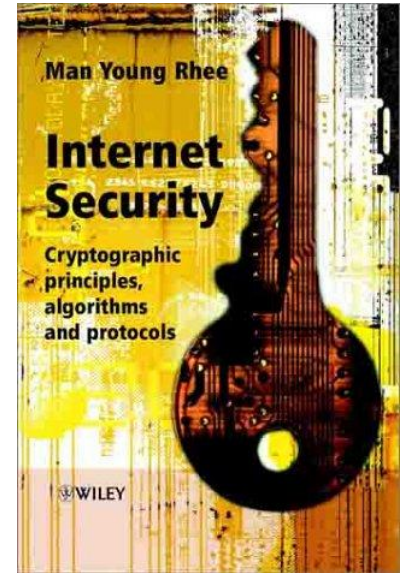
- Projets et organisation

Plan du cours

- **Contenu et objectif du cours**
 - Cryptographie et services de sécurité
 - Tiers de confiance, protocole TLS
 - Protocoles d'authentification et Kerberos
 - CyberAttaques/intrusions
 - Systèmes de détection d'intrusions
 - Tunnels de sécurité
 - Cybersécurité à l'ère de l'IA
- **Projets : techniques / recherche**
- **Evaluation :**
 - Examen final (60 %)
 - Projet avec soutenance (30%)
 - Deux TPs notés (10%)

Plan détaillé du cours

- **Introduction à la sécurité des réseaux**
 - Architecture de sécurité
 - Services ou critères de sécurité
 - Algorithmes asymétriques/symétriques
 - Fonctions de hachage
 - Cryptographies à courbes elliptiques
- **Sécurité du support de communication SSL**
 - Besoins
 - Architecture et protocoles SSL
 - Certificats de serveurs X.509
 - Faiblesses de SSL et attaques

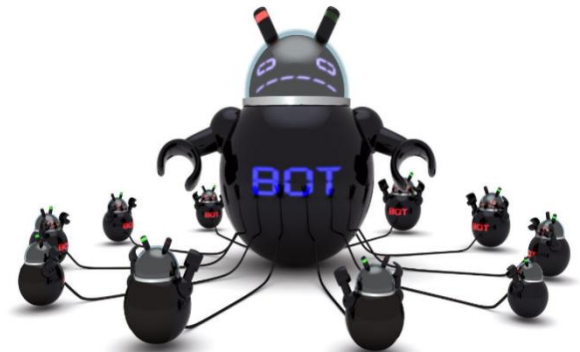
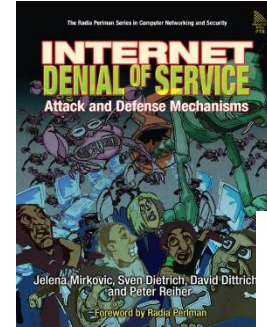


Plan détaillé du cours

- **Identité numérique et Authentification**
 - Les modèles d'identités
 - Login / mot de passe : Déclinaisons et alternatives
 - Fédération des identités
 - Formalisation des protocoles d'authentification
- **Public Key Infrastructure (PKI)**
 - Présentation du standard X509 et X509v3
 - Autorités de certification
 - Délégation de confiance
 - Révocation
 - Signature électronique et authentification

Plan détaillé du cours

- Attaques de déni de service distribuées (DDoS)
 - Contexte et historique
 - Types d'attaques
 - Spoofing
 - Smurfing
 - ICMP flooding
 - TCP flooding
 - Botnets et leurs architectures
 - Exemples de scénarios d'attaques
 - Mesures de prévention
 - Approches de détection
 - Approches de traçabilité
- *Cloud Computing* comme une plateforme d'attaques



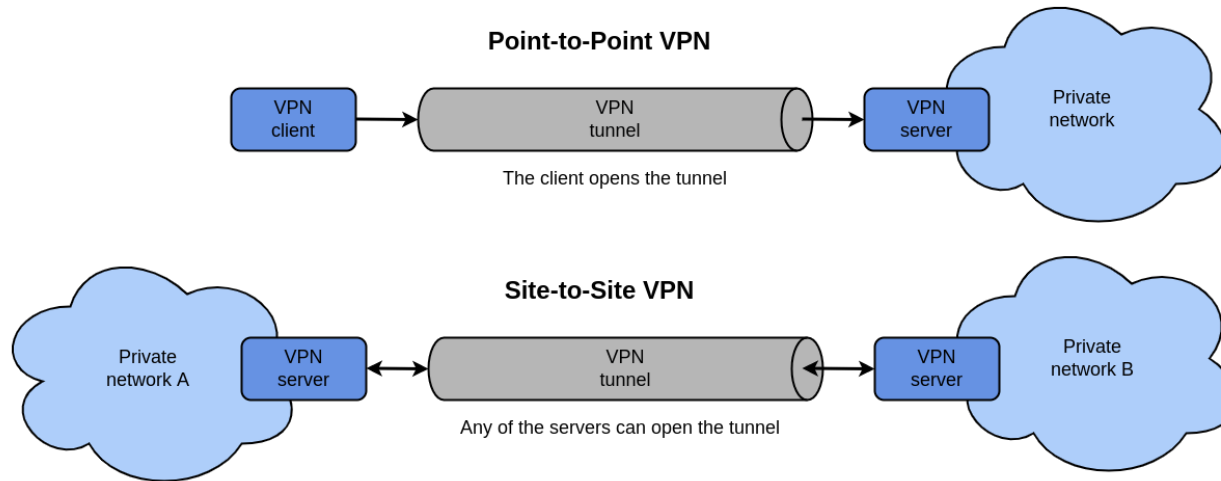
Plan détaillé du cours

- **Systèmes de détection d'intrusion**
 - Types majeurs de l'IDS
 - Détection par signature
 - Détection d'anomalies
 - Pourquoi a-t-on besoin de l'IDS?
 - Source des informations
 - HIDS
 - NIDS
 - Hybride
 - Exemple : Snort, Bro, Prelude
 - Placement d'IDS



Plan détaillé du cours

- Les VPNs
 - Types et architectures
 - Site-to-site
 - Client-to-site
 - Démonstration



- Gestion de risques

- Introduction aux risques
- Stratégie de cybersécurité dans une entreprise
- Filières de de sécurité
- Gouvernance des risques dans une organisation
- Analyse de risques
- Référentiel de contrôles ISO 27001



Plan détaillé du cours

- Risks, Threats, strategies

SAMPLE OF CYBER SECURITY GOVERNANCE STRATEGY



01 | **IT Security Roadmap**
Reviewed and validated with Top Management

02 | **IT Security Policies**
Elaboration & Follow up of the good Implementation of IT Security Policies

03 | **Proactive Risk**
Audit, Assessment and Management

04 | **IT Security Awareness**
Training Program
Implementation and Evaluation
Phishing Simulation
Campaigns

05 | **Advanced Business-Oriented CENTER**
For intelligent security operations

06 | **SECURITY POSTURE**
Continuous improvement with a multi-layered & multi-technology security approach

- Slides de cours, énoncés TD, corrigés
- Annales
 - Page : <http://rida.khatoun.free.fr/teaching.html>
 - Mot de passe : ?

- Objectif :
 - Comprendre une problématique, étudier l'état de l'art, analyser, proposer une solution
 - Rédiger un rapport/article de recherche
- Références
 - Articles publiés, revues, thèses
 - Ex :
 - <http://ieeexplore.ieee.org/Xplore/dynhome.jsp>
 - <http://www.sciencedirect.com/>
 - RFC

- Objectif :
 - Comprendre : enjeux, solution technique
 - Implémentation, test et analyse
 - Savoir rédiger un rapport technique
- Références
 - Articles
 - Blogs spécialisés
 - Etc.

Structure du rapport

- Résumé : condensé du contenu
- Introduction : objectifs, cadre du sujet et plan
- Etat de l'art
 - Définitions, hypothèses, ...
 - Illustrations techniques
 - Comparaison
- Conclusion : rappel des résultats, point de vue critique, nouvelles pistes proposées
- Références bibliographiques
- Volume minimal : 5 pages par personne

- Citations littérales autorisées mais :
 - Courtes (quelques lignes au plus)
 - Clairement identifiées comme telles (guillemets, source indiquée juste après la citation)
 - En nombre assez restreint
- Rappel : une citation présentée comme une partie de votre texte est assimilable à du plagiat

- Projet par groupe de 4 étudiants
- Désigner un animateur de groupe
- Attribution de projets
 - Sur place ou....
 - Par mail en choisissant 3 sujets avec l'ordre de priorité (l'e-mail doit être envoyé par l'animateur du groupe) au responsable de l'UE
- Suivi des projets
 - Voir le correspondant de votre projet 3 fois dans le semestre selon un planning défini ultérieurement

Projets techniques

- **Projet 1**
 - LLM-based classifier for detecting misinformation in social media posts
- **Projet 2**
 - Automated Generation of Targeted Attacks Against AI Agents
- **Projet 3**
 - Conception et développement d'un mini-SOC
 - Construire un SOC avec collecte de logs, détection d'incidents, dashboards
 - Technos : Wazuh/Elastic, Suricata, Docker, Linux.
- **Projet 4 :**
 - Assistant SOC
 - Créer un assistant capable de résumer un incident à partir de logs
 - Proposer les étapes d'investigation, avec validation humaine.
- **Projet 5**
 - Plateforme d'attaques pédagogique
 - Développer une plateforme avec des challenges (pas CTF) sur XSS, SQL injection, authentification, chiffrement, etc.
 - Explication de chaque vulnérabilité et exploitation
- **Projet 6**
 - CyberRange universitaire. Créer une infrastructure permettant à des étudiants de s'entraîner à la cybersécurité avec :
 - Machines virtuelles isolées
 - Gestion de comptes
 - Scénarios progressifs
 - Génération automatique d'événements
 - Scoring, supervision
 - Remise à zéro automatique des environnements.

Projets techniques

- **Projet 7**
 - Plugin thunderbird anti-phishing. Construire un modèle qui analyse les caractéristiques d'une URL ou d'un email et estime s'il présente des indicateurs associés au phishing.
- **Projet 8**
 - mini SOC réseau intelligent pour IoT
 - Construire un petit IDS capable d'observer le trafic d'un réseau IoT et de détecter automatiquement des comportements suspects.
 - Comportement anormal : scanner d'autres machines, contacter un serveur inhabituel, générer beaucoup plus de trafic que d'habitude, utiliser des ports/protocoles inattendus (MQTT est souvent utilisé)
 - Générer une alerte avec un score d'anomalie
 - Utiliser des méthodes simples comme Isolation Forest, clustering ou statistiques temporelles
 - Technologies possibles : Docker pour créer le mini-réseau virtuel, Suricata pour l'observation réseau, Scikit-learn pour la détection d'anomalies, Grafana pour le dashboard, Mininet pour simuler la topologie réseau
- **Projet 9**
 - Détecteur de Cyberbullying (cyberharcèlement) en ligne via IA
- **Projet 10**
 - Développer un protocole de *Zero-Knowledge authentication* pour les objets connectés

- Réunion tous les mois
- Sans plagiat
 - *Anti plagiat tool* « <https://www.compilatio.net> »
- Rôle de l'animateur
 - Porte parole du groupe
 - Organisation des réunions
 - Envoi des mails
- Mail:
 - **Sujet : Groupe X [Objectif du mail]**
 - Signature : Membres du groupe